TECH BIZ SECURITY · SOC ANALYST INTERNSHIP · BATCH B-503

WEEK 3 · TASK 7

Malware Types & Common Attacks

Submitted by	**Oscar ALIDJINOU**
Student ID	**TBS-INT-2026-2398**
Program	**SOC Analyst Internship (6 weeks)**
Company	**Tech Biz Security**
Date of submission	**30-10-2026**

01 Objective

A SOC analyst has to recognise a threat from its behaviour before anyone tells them what it is. This report covers the malware types and common attacks I must know, how each one works, and, most importantly, the signs it leaves in logs and traffic. I built it from two TryHackMe rooms (Common Attacks and Vulnerabilities 101) and from the log and detection skills of the previous weeks.

02 Proof of Completion

Room	Duration	Tasks	Status
TryHackMe: Common Attacks	40 min	10	Completed, room progress 100%
TryHackMe: Vulnerabilities 101	20 min	7	Completed, room progress 100%

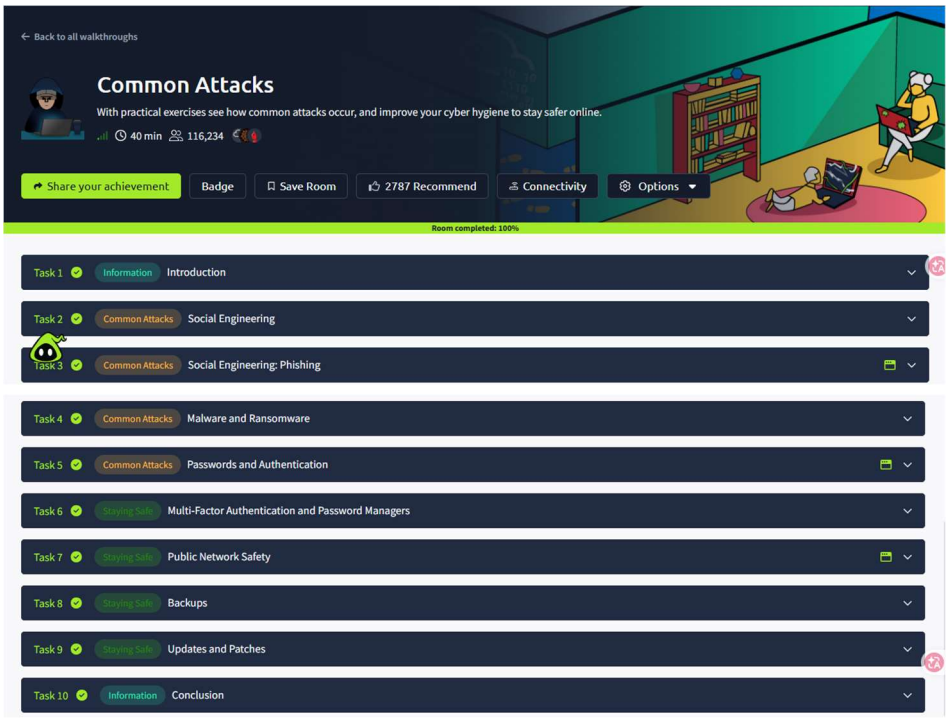


Figure 1. Common Attacks: all 10 tasks completed (100%).

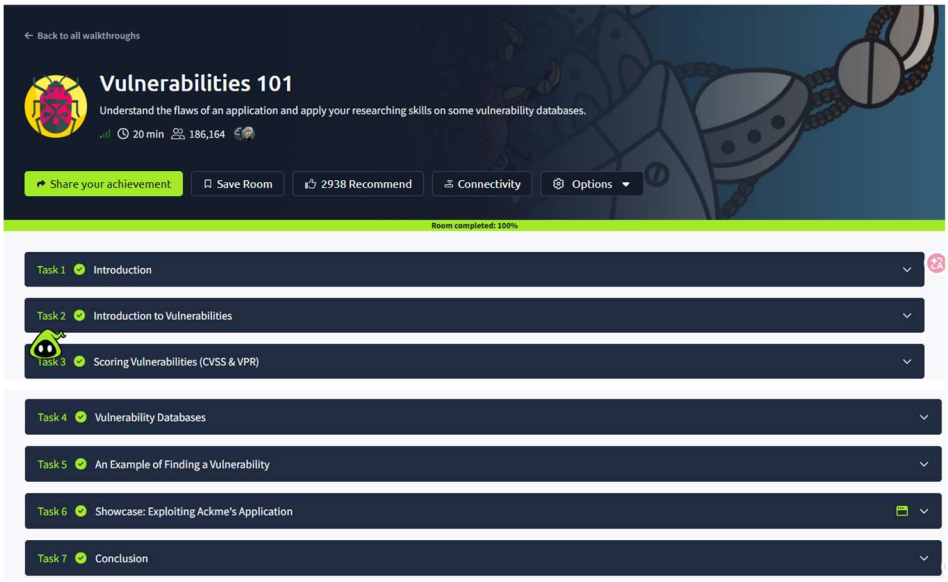


Figure 2. Vulnerabilities 101: all 7 tasks completed (100%).

What I did in the rooms

- **Phishing:** judged example emails in a simulator and decided which were phishing and which were safe.
- **Password attacks:** built a wordlist and used a browser-based hash cracker to find a password from its hash.
- **Man-in-the-middle:** used a simulator to see what an attacker on a network can observe, with and without a VPN and HTTPS.
- **Vulnerabilities:** followed an authorised penetration test from scope and scanning through to exploiting a known vulnerability in a web portal.

03 Six Types of Malware

Malware is any software written to do harm for an attacker. The six types below are the ones a SOC meets most often. The last column is what I would look for first.

Type	One-line definition	How it spreads or works	Detection sign
Virus	Malicious code that attaches itself to a legitimate file and runs when that file is opened.	Spreads when infected files are shared, copied or run by a user.	A program or document whose hash or size changed; antivirus signature hits; software behaving oddly.
Worm	Self-replicating malware that spreads across a network by itself.	Exploits an unpatched vulnerability to jump from machine to machine, with no user action.	A sudden wave of scanning and connections between many hosts, such as many connections to port 445; IDS alerts.
Trojan	Malware disguised as useful software so the user installs it willingly.	Delivered as a fake installer, cracked software or an email attachment; often opens a backdoor for remote control.	A new, unknown program that connects to an outside IP; an executable running from Downloads or Public.
Ransomware	Malware that encrypts a victim's files and demands payment for the key.	Arrives through phishing, exposed remote access or unpatched services, then spreads inside the network.	Mass file changes or renames, ransom notes, deleted backups, a surge in disk activity.
Spyware	Malware that secretly collects information, such as keystrokes, screens and passwords.	Installed by trojans, bundled with free software or dropped by other malware.	An unknown process hooking the keyboard; regular small uploads to an unfamiliar host; unexpected browser extensions.
Rootkit	Malware that hides itself and the attacker's access by modifying the operating system.	Installed after an attacker gains administrator rights; works deep in the kernel or boot process.	Tools disagree (a connection that no process list shows); integrity checks fail; clean-boot scans find what the live system hides.

> **Virus, worm, trojan: the key difference**
> A virus needs a host file and a user to run it. A worm needs neither: it spreads by itself over the network. A trojan does not spread by itself; it relies on tricking the user into running it.

Other terms I may meet

- **Backdoor / RAT:** gives an attacker remote control of a machine; often delivered by a trojan.
- **Keylogger:** a kind of spyware that records what the user types.
- **Botnet:** a network of infected machines controlled together, used for DDoS attacks and spam.

04 Ransomware: Spread, Impact and Defence

4.1 How it spreads

- **Phishing:** a malicious attachment or link is the most common way in.
- **Unpatched vulnerabilities:** attackers use known flaws, such as the EternalBlue weakness in Windows file sharing (SMB) that the room used as a case study.

- **Exposed remote access:** Remote Desktop open to the internet with weak or stolen passwords.
- **Other routes:** malicious downloads and unknown USB drives.

Once inside, ransomware usually spreads to other machines with stolen credentials and network file sharing, so that it encrypts as much as possible before anyone reacts.

4.2 Stages of an attack

	Stage	What happens
1	Initial access	A user opens a phishing attachment, or the attacker uses an exposed service.
2	Execution and spread	The malware runs, gains higher privileges and moves to other machines.
3	Preparation	Backups and shadow copies are deleted so that recovery is harder.
4	Encryption	Files are encrypted, often with a new file extension.
5	Ransom demand	A ransom note is left; payment is demanded, usually in cryptocurrency.

4.3 Impact

Area	Consequence
Availability	Systems and files are unusable, so work stops until they are restored.
Data	Files can be lost for good if there is no backup. Many groups also steal data first and threaten to publish it.
Money	Ransom payment, downtime, recovery costs and lost business.
Reputation and law	Loss of customer trust, and possible legal duties after a data breach.

4.4 Detection signs and defence

- Many files modified or renamed in a short time, especially with a new extension, and ransom note files appearing in folders.
- Commands that delete shadow copies or backups, visible in process-creation logs (Event ID 4688).
- A surge in file-sharing traffic between hosts and a jump in disk activity.

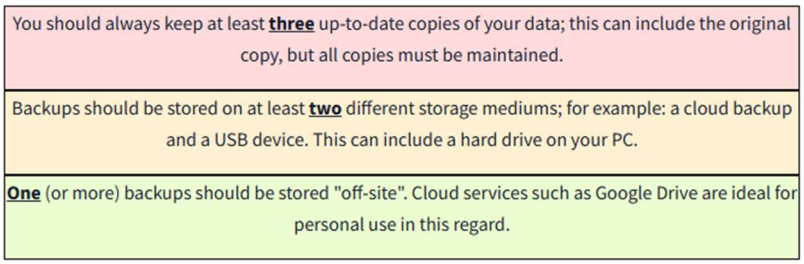


Figure 3. The 3-2-1 backup rule: three copies, on two kinds of storage, with one kept off-site.

> **Best defences**
> Tested backups following the 3-2-1 rule, fast patching, multi-factor authentication, no open Remote Desktop, and training users to spot phishing.

05 Common Attacks

5.1 Phishing

Phishing is a form of social engineering, an attack that targets the person rather than the computer. The attacker sends a message that looks like it comes from a trusted sender, to trick the victim into acting. The same trick over SMS is called smishing and over a phone call vishing.

Step	What happens
Bait	A message pretends to be a bank, a colleague or a service, and creates urgency ("your account was accessed").
Hook	It contains a link to a fake page, an attachment, or a number to call.
Capture	The fake page steals the password, or the attachment installs malware.
Abuse	The attacker signs in as the victim or moves deeper into the network.

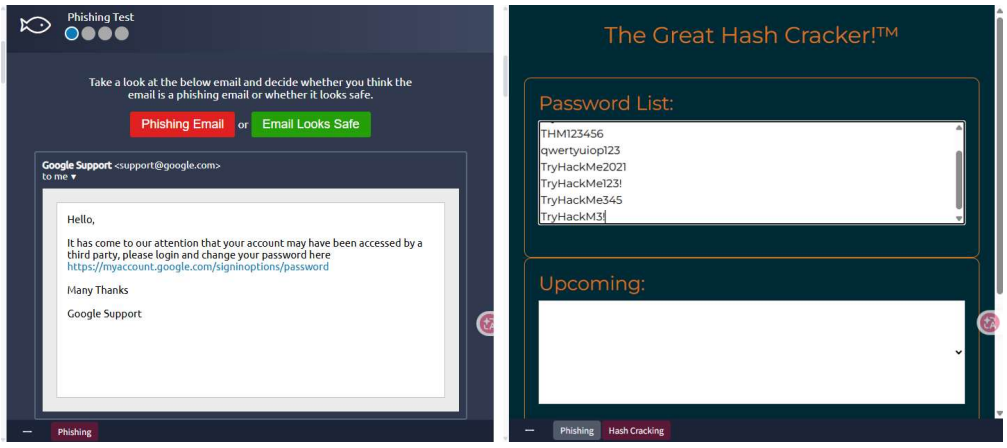


Figure 4. A phishing test email in the room, and the wordlist I used in the hash cracker.

Red flags I learned to check: a sender address or link whose domain is slightly wrong, an unexpected attachment (even from a known contact), urgency or threats, requests for a password, and generic greetings.

> **Detection signs**
> Look in the email gateway and user reports for look-alike domains and failed SPF, DKIM or DMARC checks. In proxy and DNS logs, look for a user visiting a newly registered domain right after receiving the email. After a click, look for a sign-in from an unusual place, or Word or Excel starting PowerShell.

5.2 Brute force and password attacks

A brute-force attack guesses passwords until one works. Variants include dictionary attacks (trying a list of common passwords), credential stuffing (reusing passwords leaked elsewhere) and password spraying (trying one common password across many accounts). There are two settings: online, against a live login such as SSH or Remote Desktop, and offline, where the attacker has stolen password hashes and tests guesses on their own computer.

The hash cracker in the room showed the offline idea: it hashes every word in a list and compares each result with the target hash until one matches. A weak password falls almost instantly, which is why length, randomness and not reusing passwords matter.

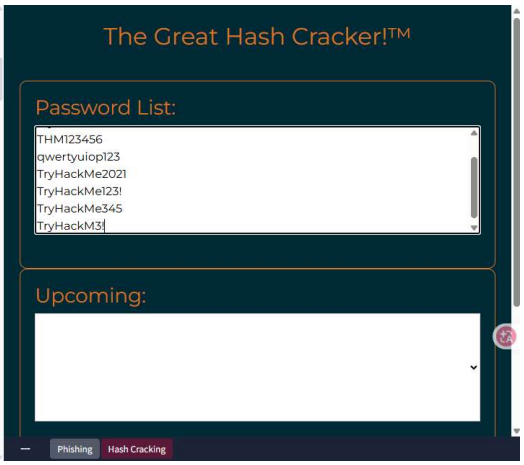


Figure 5. The browser-based hash cracker and its password list.

Where	What I would look for
Linux (auth.log)	Many "Failed password" lines for one account or from one IP, then possibly an "Accepted" line.
Windows (Security log)	A burst of Event ID 4625 followed by a 4624 success, account lockouts (4740), and one source trying many accounts.
Web login pages	Many POST requests to the login page from one IP in a short time.

I practised this already: in my Week 2 reports I produced failed SSH logins on a lab machine and analysed a real 4625 event, so I know how these patterns look in real logs.

5.3 Denial of Service (DoS and DDoS)

A denial-of-service attack tries to make a service unavailable by overwhelming it with more traffic or requests than it can handle. When the traffic comes from many machines at once, usually a botnet, it is a distributed attack (DDoS), which is harder to block because there is no single source.

Type	How it works	Example
Volumetric	Floods the network link with huge amounts of traffic.	UDP or reflection floods.
Protocol	Exhausts server or firewall resources by abusing how protocols work.	SYN flood: many half-open connections.
Application	Sends many legitimate-looking requests to a costly page.	HTTP flood on a login or search page.

> **Detection signs**
> A sudden traffic spike compared with the baseline, a huge number of connections in the half-open state, many requests per second to the same URL, rising 503 errors and timeouts, and high CPU or bandwidth use. In a web log, counting requests per IP quickly shows whether one source or thousands are responsible.

```
awk '{print $1}' /var/log/apache2/access.log | sort | uniq -c | sort -nr | head
```

5.4 Man-in-the-Middle (MITM)

In a man-in-the-middle attack, the attacker places themselves between a user and the service they are using, so that all traffic passes through them. This is easy on open public Wi-Fi, where an attacker can run a rogue network, or on a local network using techniques such as ARP spoofing. The attacker can read unencrypted traffic and even change it.

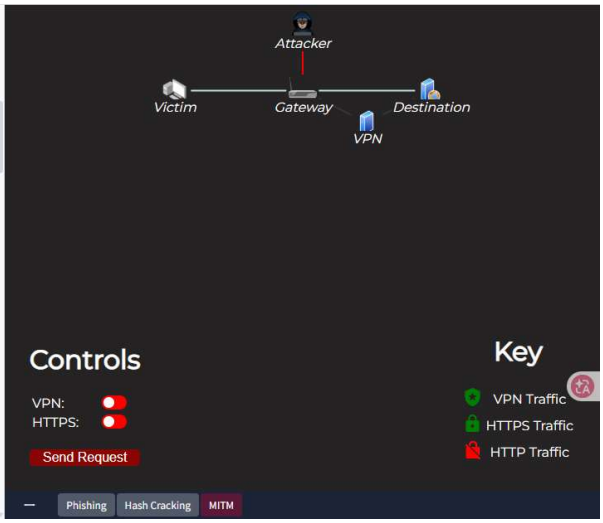


Figure 6. The room's simulator: victim, gateway and destination, with an attacker watching, and switches for VPN and HTTPS.

The simulator marks traffic as VPN, HTTPS or plain HTTP. Plain HTTP can be read by the attacker; HTTPS and a VPN encrypt the data so that the attacker sees only unreadable traffic. That is why public networks call for HTTPS and a VPN.

> **Detection signs**
> Certificate warnings or sudden TLS errors, two different MAC addresses claiming the same IP (a changed ARP entry for the gateway), unexpected DNS answers, a rogue Wi-Fi network with a familiar name, and IDS alerts for ARP spoofing.

06 Attack Detection Summary

Threat	Detection sign	Where to look	MITRE ATT&CK
Phishing	Look-alike domain, user click on a new domain, Office spawning PowerShell.	Email gateway, proxy and DNS logs, process creation.	T1566
Brute force	Bursts of failed logons, then a success.	auth.log, Windows 4625 and 4624.	T1110
DoS / DDoS	Traffic spike over baseline, many half-open connections.	Firewall, web server and network logs.	T1498, T1499
Man-in-the-Middle	ARP changes, certificate errors, rogue Wi-Fi.	ARP table, IDS, TLS and DNS logs.	T1557
Ransomware	Mass file renames, deleted backups, ransom notes.	Endpoint logs, process creation, file activity.	T1486, T1490
Worm	Wide scanning and spreading between hosts.	Network flows, IDS, SMB traffic.	T1210
Spyware	Keyboard hooks, small regular uploads.	EDR alerts, outbound proxy logs.	T1056
Rootkit	Hidden processes or ports, integrity failures.	EDR, offline scan, file integrity checks.	T1014

07 Vulnerabilities 101

A vulnerability is a weakness in the design, implementation or behaviour of a system that an attacker can use to gain access or perform unauthorised actions. An exploit is the action or tool that uses the weakness, and a proof of concept (PoC) is a demonstration that it can be exploited.

Vulnerability type	Description
Operating system	Flaws in the OS itself, often leading to privilege escalation.
Misconfiguration	A service set up incorrectly, such as a website exposing customer details.
Weak or default credentials	Default logins like admin/admin that were never changed.
Application logic	Poorly designed features, such as a flawed login that lets someone impersonate a user.
Human factor	Weaknesses that rely on human behaviour, such as phishing.

Scoring vulnerabilities: CVSS and VPR

	CVSS	VPR
What it is	A free, long-established standard that gives each vulnerability a severity score.	A modern, risk-driven score used inside commercial platforms.
Scale	0 to 10: None 0, Low 0.1-3.9, Medium 4.0-6.9, High 7.0-8.9, Critical 9.0-10.0.	0 to 10: Low, Medium, High, Critical.
Strength	Widely adopted, recommended by NIST, strong focus on confidentiality, integrity and availability.	Considers over 150 factors and changes over time, so it helps prioritise patching.
Weakness	Does not prioritise well, rarely updates, and leans on exploits that exist for only a fraction of flaws.	Not open-source and only available in a commercial product.

Where to research: public vulnerability databases such as the National Vulnerability Database (NVD) and Exploit-DB list known flaws by CVE number, with their scores and, for some, exploit code.

The ACKme showcase: a vulnerability found and used

The room followed a junior penetration tester on an authorised engagement. The client's email set a strict scope, a single IP address, and anything outside it was off limits. The steps showed how research turns into exploitation:

	Step	What happened
1	Scope	Only the IP address named by the client could be tested.
2	Scan	An Nmap scan showed three open ports: 22 (SSH), 80 (HTTP) and 443 (HTTPS).
3	Identify	The web service was a login portal that displayed its name and version, ACKme Portal 1.5.2.
4	Research	Searching the name and version in a vulnerability database found a remote code execution flaw.
5	Exploit	Running the matching exploit against the authorised target gave access as an administrator.

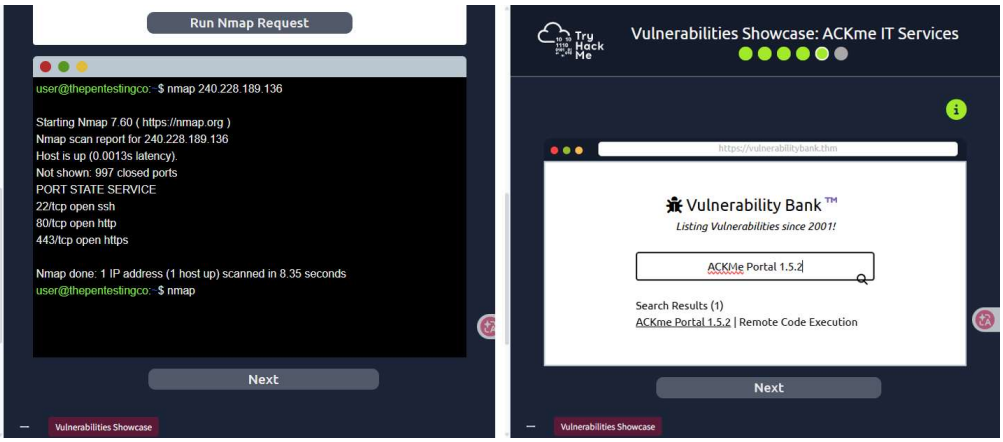


Figure 7. The Nmap scan of the authorised target, and the vulnerability database search for the portal's version.

Why a SOC analyst cares
Attackers do exactly this research. A version number shown on a login page, or an old unpatched service, is enough to find a ready-made exploit. Fast patching and a vulnerability list ranked by real risk are the defence, and scans for a known vulnerable version are a sign to watch for in logs.

08 Defences from Common Attacks

Defence	How it helps	Counters
Strong, unique passwords and a password manager	Long random passwords resist guessing and cracking; a manager makes them practical.	Brute force
Multi-factor authentication	A stolen or guessed password is not enough to log in.	Phishing, brute force
Updates and patches	Closes known flaws before attackers use them, as the EternalBlue case showed.	Worms, ransomware
Backups (3-2-1)	Allows recovery without paying a ransom.	Ransomware
HTTPS and a VPN on public networks	Encrypts traffic so an observer learns nothing.	Man-in-the-middle
User awareness	People who spot suspicious messages stop the attack at the first step.	Phishing, social engineering
Antivirus with current signatures	Detects known malware.	Viruses, trojans

09 Reflection and Key Takeaways

- Each threat has a mechanism and a footprint. If I understand the mechanism, I know which log to open to find the footprint.
- Many attacks start with a person, not a machine, so awareness and multi-factor authentication matter as much as technical controls.
- A baseline from Week 2 makes denial-of-service and scanning easier to detect, because I can see what departs from normal.
- Researching a version number and finding an exploit in minutes shows why patching speed is critical.

Next step: practise spotting these signs in real alerts inside a SIEM.

10 References

- TryHackMe: Common Attacks and Vulnerabilities 101 (free rooms)
- MITRE ATT&CK: techniques T1566, T1110, T1498, T1499, T1557, T1486, T1490, T1210, T1056 and T1014
- National Vulnerability Database and Exploit-DB